

SupplyShield

Enterprise Portfolio Report

Generated 12 Jul 2026, 09:39 | Audit-ready software supply chain analysis

Executive Summary

SupplyShield assessed **10** application(s) and **500** dependency instance(s). The highest in-scope risk is **InternalAPI** at **26.67** (Medium). The scope contains **2** critical dependency-risk assessment(s).

Portfolio Risk Summary

Applications	10	Dependencies	500
Highest risk	26.67	Critical apps	0

Application Risk Ranking

Rank	Application	Dependencies	Vulnerable	License issues	Outdated	Score	Level
1	InternalAPI	50	20	7	11	26.67	Medium
2	VendorGateway	50	23	5	7	23.52	Low
3	CustomerPortal	50	20	3	12	23.42	Low
4	HRPortal	50	21	2	9	22.59	Low
5	MobileBackend	50	20	4	11	22.30	Low
6	NotificationService	50	18	5	10	22.07	Low
7	DevToolkit	50	17	1	11	21.74	Low
8	ComplianceEngine	50	18	2	10	21.01	Low
9	PaymentService	50	16	2	9	20.14	Low
10	AnalyticsDashboard	50	21	3	6	20.11	Low

Critical Vulnerabilities

Application	Library	Version	CVE	CVSS	Severity	Patch
CustomerPortal	lombok	4.1.2	CVE-2023-1002	9.9	Critical	Available
CustomerPortal	pyyaml	5.7.10	CVE-2022-1069	9.3	Critical	Available
CustomerPortal	hibernate-validator	1.13.1	CVE-2024-1060	9.7	Critical	Available
PaymentService	testify	2.2.6	CVE-2025-1043	9.9	Critical	Available
PaymentService	lombok	3.12.5	CVE-2023-1002	9.9	Critical	Available
InternalAPI	pyyaml	2.15.5	CVE-2022-1069	9.3	Critical	Available
InternalAPI	httpx	4.5.8	CVE-2025-1096	9.6	Critical	Available
InternalAPI	httpx	4.5.8	CVE-2023-1097	9.7	Critical	Available

Application	Library	Version	CVE	CVSS	Severity	Patch
InternalAPI	zap	2.8.3	CVE-2021-1014	9.5	Critical	Available
HRPortal	httpx	3.6.5	CVE-2025-1096	9.6	Critical	Available
HRPortal	httpx	3.6.5	CVE-2023-1097	9.7	Critical	Available
HRPortal	hibernate-validator	1.4.0	CVE-2024-1060	9.7	Critical	Available
AnalyticsDashboard	sequelize	3.2.9	CVE-2023-1167	9.4	Critical	Available
AnalyticsDashboard	commander	2.13.9	CVE-2024-1126	9.5	Critical	Available
AnalyticsDashboard	babel-core	5.15.3	CVE-2025-1106	9.8	Critical	Available
AnalyticsDashboard	testify	2.9.8	CVE-2025-1043	9.9	Critical	Available
MobileBackend	zap	4.6.3	CVE-2021-1014	9.5	Critical	Available
DevToolkit	httpx	3.2.1	CVE-2025-1096	9.6	Critical	Available
DevToolkit	httpx	3.2.1	CVE-2023-1097	9.7	Critical	Available
DevToolkit	pyyaml	4.11.5	CVE-2022-1069	9.3	Critical	Available
ComplianceEngine	hibernate-validator	2.7.7	CVE-2024-1060	9.7	Critical	Available
NotificationService	babel-core	5.0.0	CVE-2025-1106	9.8	Critical	Available
NotificationService	sequelize	2.12.8	CVE-2023-1167	9.4	Critical	Available
NotificationService	commander	3.12.7	CVE-2024-1126	9.5	Critical	Available
VendorGateway	cobra	3.5.6	CVE-2025-1164	9.6	Critical	Available
VendorGateway	zap	2.12.6	CVE-2021-1014	9.5	Critical	Available
VendorGateway	hibernate-validator	2.4.0	CVE-2024-1060	9.7	Critical	Available

License Compliance Issues

Application	Library	License	Status	Severity	Recommendation
CustomerPortal	go-jwt	UNKNOWN	Unknown	High	Obtain a verified SPDX license declaration or replace the dependency.
CustomerPortal	kafka-clients	GPL-3.0	Incompatible	CRITICAL	Replace the dependency, obtain an approved exception, or change the application policy.
CustomerPortal	jackson-core	AGPL-3.0	Incompatible	CRITICAL	Replace the dependency, obtain an approved exception, or change the application policy.
PaymentService	spring-web	UNKNOWN	Unknown	High	Obtain a verified SPDX license declaration or replace the dependency.
PaymentService	netty-all	AGPL-3.0	Incompatible	CRITICAL	Replace the dependency, obtain an approved exception, or change the application policy.
InternalAPI	requests	GPL-2.0	Incompatible	CRITICAL	Replace the dependency, obtain an approved exception, or change the application policy.
InternalAPI	twisted	UNKNOWN	Unknown	High	Obtain a verified SPDX license declaration or replace the dependency.
InternalAPI	psycpg2	AGPL-3.0	Incompatible	CRITICAL	Replace the dependency, obtain an approved exception, or change the application policy.

Application	Library	License	Status	Severity	Recommendation
InternalAPI	markupsafe	AGPL-3.0	Incompatible	CRITICAL	Replace the dependency, obtain an approved exception, or change the application policy.
InternalAPI	cryptography	GPL-2.0	Incompatible	CRITICAL	Replace the dependency, obtain an approved exception, or change the application policy.
InternalAPI	safety	GPL-2.0	Incompatible	CRITICAL	Replace the dependency, obtain an approved exception, or change the application policy.
InternalAPI	pillow	UNKNOWN	Unknown	High	Obtain a verified SPDX license declaration or replace the dependency.
HRPortal	twisted	AGPL-3.0	Incompatible	CRITICAL	Replace the dependency, obtain an approved exception, or change the application policy.
HRPortal	markupsafe	UNKNOWN	Unknown	High	Obtain a verified SPDX license declaration or replace the dependency.
AnalyticsDashboard	sequelize	AGPL-3.0	Incompatible	CRITICAL	Replace the dependency, obtain an approved exception, or change the application policy.
AnalyticsDashboard	knex	GPL-2.0	Incompatible	CRITICAL	Replace the dependency, obtain an approved exception, or change the application policy.
AnalyticsDashboard	micrometer-core	UNKNOWN	Unknown	High	Obtain a verified SPDX license declaration or replace the dependency.
MobileBackend	aws-sdk-go	AGPL-3.0	Incompatible	CRITICAL	Replace the dependency, obtain an approved exception, or change the application policy.
MobileBackend	json-iterator	GPL-2.0	Incompatible	CRITICAL	Replace the dependency, obtain an approved exception, or change the application policy.
MobileBackend	numpy	GPL-3.0	Incompatible	CRITICAL	Replace the dependency, obtain an approved exception, or change the application policy.
MobileBackend	uuid	UNKNOWN	Unknown	High	Obtain a verified SPDX license declaration or replace the dependency.
DevToolkit	gunicorn	UNKNOWN	Unknown	High	Obtain a verified SPDX license declaration or replace the dependency.
ComplianceEngine	guava	GPL-2.0	Incompatible	CRITICAL	Replace the dependency, obtain an approved exception, or change the application policy.
ComplianceEngine	logback-core	UNKNOWN	Unknown	High	Obtain a verified SPDX license declaration or replace the dependency.
NotificationService	nanoid	UNKNOWN	Unknown	High	Obtain a verified SPDX license declaration or replace the dependency.
NotificationService	lodash	GPL-2.0	Incompatible	CRITICAL	Replace the dependency, obtain an approved exception, or change the application policy.
NotificationService	moment	AGPL-3.0	Incompatible	CRITICAL	Replace the dependency, obtain an approved exception, or change the application policy.
NotificationService	prettier	UNKNOWN	Unknown	High	Obtain a verified SPDX license declaration or replace the dependency.
NotificationService	nats	GPL-3.0	Incompatible	CRITICAL	Replace the dependency, obtain an approved exception, or change the application policy.
VendorGateway	logrus	GPL-2.0	Incompatible	CRITICAL	Replace the dependency, obtain an approved exception, or change the application policy.

Application	Library	License	Status	Severity	Recommendation
VendorGateway	chi	UNKNOWN	Unknown	High	Obtain a verified SPDX license declaration or replace the dependency.
VendorGateway	yaml-go	UNKNOWN	Unknown	High	Obtain a verified SPDX license declaration or replace the dependency.
VendorGateway	pip	UNKNOWN	Unknown	High	Obtain a verified SPDX license declaration or replace the dependency.
VendorGateway	bouncycastle-bcprov	UNKNOWN	Unknown	High	Obtain a verified SPDX license declaration or replace the dependency.

Maintenance Health

Maintenance Status	Dependencies	Risk Level	Recommended Action
Actively Maintained	169	Low	Continue monitoring releases and advisories.
Moderately Outdated	235	Medium	Schedule upgrade review.
Outdated	36	High	Prioritize upgrade or supported replacement.
Unmaintained	60	Critical	Replace, isolate, or formally approve an exception.

Risk Distribution

Risk Level	Applications
Critical	0
High	0
Medium	1
Low	9

Recommended Remediation

1. Address **27** critical vulnerability finding(s) first; apply available patches or replace affected components.
2. Resolve **34** license compliance exception(s) through replacement, legal review, or approved policy exception.
3. Remediate **60** unmaintained dependency instance(s) by upgrading, replacing, or isolating them.
4. Prioritize the highest-risk application, **InternalAPI**, in the remediation plan.